

ISO/IEC 27001:2022 — RAG-Friendly Requirements

Outline and Annex A Controls

Prepared for: Akash Dravid (Votal AI Workspace) | Date: January 29, 2026

Copyright note: ISO/IEC 27001 is a copyrighted standard. This document does not reproduce the official text; it provides a complete structural outline of clauses/subclauses and a paraphrased Annex A control catalog with control identifiers for implementation and retrieval.

RAG chunking rules used in this PDF

- Each requirement subclause (4.1 to 10.2) is one chunk and starts with [CHUNK_START] and ends with [CHUNK_END].
- Each Annex A control (A.5.1 to A.8.34) is one chunk and starts with [CHUNK_START] and ends with [CHUNK_END].
- Each chunk includes stable identifiers (ChunkID and ControlID/ClauseID) and simple fields that are easy to parse.

Reference sources for control names/structure (used only to verify the list of IDs and control titles)

- High Table (Annex A list of 93 controls, grouped by themes): <https://hightable.io/iso-27001-annex-a-controls-reference-guide/>
- BSI PDF overview of ISO/IEC 27002:2022 controls themes/counts (93 controls): https://www.bsigroup.com/contentassets/af46540ce1ec4336955c49fe0ab62fd3/iso_isoiec-27002-2022--information-security-controls-update.pdf
- ISMS.online (Annex A 2022 guidance pages, used as sanity checks for titles): <https://www.isms.online/iso-27001/annex-a-2022/>

Part 1 — ISO/IEC 27001 Requirements (Clauses 4 to 10)

Paraphrased implementation-oriented summaries per subclause.

Clause 4 — Context of the organization

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-4.1

Type: ISO27001_Requirement

ClauseID: CL4.1

Subclause: 4.1

Title: Understanding the organization and its context

Summary: Determine internal and external issues relevant to the ISMS and its intended outcomes.

KeyRequirements:

- Document relevant internal/external issues and how they impact the ISMS.
- Maintain evidence that scope and boundaries were determined using issues, interested parties, and interfaces.
- Define and operate ISMS processes and their interactions.

TypicalEvidence:

- context analysis document
- interested parties & requirements register
- ISMS scope statement

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-4.2

Type: ISO27001_Requirement

ClauseID: CL4.2

Subclause: 4.2

Title: Understanding the needs and expectations of interested parties

Summary: Identify interested parties, their relevant requirements, and which become ISMS requirements.

KeyRequirements:

- Document relevant internal/external issues and how they impact the ISMS.
- Maintain evidence that scope and boundaries were determined using issues, interested parties, and interfaces.

- Define and operate ISMS processes and their interactions.

TypicalEvidence:

- context analysis document
- interested parties & requirements register
- ISMS scope statement

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-4.3

Type: ISO27001_Requirement

ClauseID: CL4.3

Subclause: 4.3

Title: Determining the scope of the ISMS

Summary: Define ISMS boundaries and applicability, considering issues, interested parties, and interfaces/dependencies.

KeyRequirements:

- Document relevant internal/external issues and how they impact the ISMS.
- Maintain evidence that scope and boundaries were determined using issues, interested parties, and interfaces.
- Define and operate ISMS processes and their interactions.

-

TypicalEvidence:

- context analysis document
- interested parties & requirements register
- ISMS scope statement

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-4.4

Type: ISO27001_Requirement

ClauseID: CL4.4

Subclause: 4.4

Title: Information security management system

Summary: Establish, implement, maintain, and continually improve the ISMS and its processes.

KeyRequirements:

- Document relevant internal/external issues and how they impact the ISMS.
- Maintain evidence that scope and boundaries were determined using issues, interested parties, and interfaces.
- Define and operate ISMS processes and their interactions.

TypicalEvidence:

- context analysis document
- interested parties & requirements register
- ISMS scope statement Clause 5 — Leadership

[CHUNK_END]

Clause 5 — Leadership

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-5.1

Type: ISO27001_Requirement

ClauseID: CL5.1

Subclause: 5.1

Title: Leadership and commitment

Summary: Top management must demonstrate commitment and integrate ISMS requirements into business processes.

KeyRequirements:

- Show top management involvement (direction, resources, accountability).
- Maintain a current information security policy and ensure it is communicated.
- Assign ISMS roles and ensure responsibilities are understood.

TypicalEvidence:

- top management commitment evidence (minutes, approvals)
- information security policy
- roles & responsibilities matrix (RACI)

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-5.2

Type: ISO27001_Requirement

ClauseID: CL5.2

Subclause: 5.2

Title: Information security policy

Summary: Establish a policy appropriate to purpose, includes objectives, and commitment to satisfy requirements and continual improvement.

KeyRequirements:

- Show top management involvement (direction, resources, accountability).
- Maintain a current information security policy and ensure it is communicated.
- Assign ISMS roles and ensure responsibilities are understood.

TypicalEvidence:

- top management commitment evidence (minutes, approvals)
- information security policy
- roles & responsibilities matrix (RACI)

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-5.3

Type: ISO27001_Requirement

ClauseID: CL5.3

Subclause: 5.3

Title: Organizational roles, responsibilities and authorities

Summary: Assign and communicate ISMS responsibilities and authorities.

KeyRequirements:

- Show top management involvement (direction, resources, accountability).
- Maintain a current information security policy and ensure it is communicated.
- Assign ISMS roles and ensure responsibilities are understood.

TypicalEvidence:

-

- top management commitment evidence (minutes, approvals)
- information security policy
- roles & responsibilities matrix (RACI) Clause 6 — Planning

[CHUNK_END]

Clause 6 — Planning

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-6.1

Type: ISO27001_Requirement

ClauseID: CL6.1

Subclause: 6.1

Title: Actions to address risks and opportunities

Summary: Plan how to address ISMS risks/opportunities; define information security risk assessment and risk treatment processes.

KeyRequirements:

- Operate a defined risk assessment method with criteria and repeatable outputs.
- Create and maintain a risk treatment plan and Statement of Applicability (SoA).
- Define measurable objectives and plan changes in a controlled manner.

TypicalEvidence:

- risk assessment methodology
- risk register

- risk treatment plan

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-6.2

Type: ISO27001_Requirement

ClauseID: CL6.2

Subclause: 6.2

Title: Information security objectives and planning to achieve them

Summary: Set measurable objectives, communicate them, and plan actions/resources/owners/timelines/evaluation.

KeyRequirements:

- Operate a defined risk assessment method with criteria and repeatable outputs.
- Create and maintain a risk treatment plan and Statement of Applicability (SoA).
- Define measurable objectives and plan changes in a controlled manner.

TypicalEvidence:

- risk assessment methodology
- risk register
- risk treatment plan

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-6.3

Type: ISO27001_Requirement

ClauseID: CL6.3

Subclause: 6.3

Title: Planning of changes

Summary: Plan ISMS changes in a controlled manner (purpose, consequences, integrity, resources, responsibilities).

KeyRequirements:

- Operate a defined risk assessment method with criteria and repeatable outputs.
- Create and maintain a risk treatment plan and Statement of Applicability (SoA).
-
- Define measurable objectives and plan changes in a controlled manner.

TypicalEvidence:

- risk assessment methodology
- risk register
- risk treatment plan Clause 7 — Support

[CHUNK_END]

Clause 7 — Support

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-7.1

Type: ISO27001_Requirement

ClauseID: CL7.1

Subclause: 7.1

Title: Resources

Summary: Determine and provide resources needed for the ISMS.

KeyRequirements:

- Provide resources and ensure competence/awareness for ISMS roles.
- Define communications (internal/external) and retain evidence it happens.
- Control documented information: creation, updates, access, retention, and disposal.

TypicalEvidence:

- competence and training records
- communications plan
- controlled document procedures and logs

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-7.2

Type: ISO27001_Requirement

ClauseID: CL7.2

Subclause: 7.2

Title: Competence

Summary: Ensure persons are competent; take actions to acquire competence and retain evidence.

KeyRequirements:

- Provide resources and ensure competence/awareness for ISMS roles.
- Define communications (internal/external) and retain evidence it happens.
- Control documented information: creation, updates, access, retention, and disposal.

TypicalEvidence:

- competence and training records
- communications plan
- controlled document procedures and logs

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-7.3

Type: ISO27001_Requirement

ClauseID: CL7.3

Subclause: 7.3

Title: Awareness

Summary: Ensure persons are aware of policy, their contribution, benefits of performance, and implications of nonconformance.

KeyRequirements:

- Provide resources and ensure competence/awareness for ISMS roles.
- Define communications (internal/external) and retain evidence it happens.
- Control documented information: creation, updates, access, retention, and disposal.

TypicalEvidence:

- competence and training records
- communications plan
- controlled document procedures and logs

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-7.4

Type: ISO27001_Requirement

ClauseID: CL7.4

Subclause: 7.4

Title: Communication

Summary: Determine internal/external communications: what, when, with whom, and how.

KeyRequirements:

- Provide resources and ensure competence/awareness for ISMS roles.
- Define communications (internal/external) and retain evidence it happens.
- Control documented information: creation, updates, access, retention, and disposal.

TypicalEvidence:

- competence and training records
- communications plan
- controlled document procedures and logs

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-7.5

Type: ISO27001_Requirement

ClauseID: CL7.5

Subclause: 7.5

Title: Documented information

Summary: Maintain documented information required by the standard and determined as necessary.

KeyRequirements:

- Provide resources and ensure competence/awareness for ISMS roles.
- Define communications (internal/external) and retain evidence it happens.
- Control documented information: creation, updates, access, retention, and disposal.

TypicalEvidence:

- competence and training records
- communications plan
- controlled document procedures and logs

[CHUNK_END]

Clause 8 — Operation

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-8.1

Type: ISO27001_Requirement

ClauseID: CL8.1

Subclause: 8.1

Title: Operational planning and control

Summary: Plan, implement, and control processes; implement actions from Clause 6; control changes and unintended changes.

KeyRequirements:

- Plan and control ISMS operations; manage changes and unintended changes.
- Run risk assessments at planned intervals and when changes occur.
- Implement the risk treatment plan and retain evidence of results.

TypicalEvidence:

- operational procedures
- risk assessment outputs for changes
- implemented controls evidence

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-8.2

Type: ISO27001_Requirement

ClauseID: CL8.2

Subclause: 8.2

Title: Information security risk assessment

Summary: Perform risk assessments at planned intervals and when changes are proposed or occur.

KeyRequirements:

- Plan and control ISMS operations; manage changes and unintended changes.
- Run risk assessments at planned intervals and when changes occur.
- Implement the risk treatment plan and retain evidence of results.

TypicalEvidence:

- operational procedures
- risk assessment outputs for changes
- implemented controls evidence

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-8.3

Type: ISO27001_Requirement

ClauseID: CL8.3

Subclause: 8.3

Title: Information security risk treatment

Summary: Implement the risk treatment plan; maintain documented information on results.

KeyRequirements:

- Plan and control ISMS operations; manage changes and unintended changes.
- Run risk assessments at planned intervals and when changes occur.
- Implement the risk treatment plan and retain evidence of results.

TypicalEvidence:

- operational procedures
- risk assessment outputs for changes
- implemented controls evidence Clause 9 — Performance evaluation

[CHUNK_END]

Clause 9 — Performance evaluation

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-9.1

Type: ISO27001_Requirement

ClauseID: CL9.1

Subclause: 9.1

Title: Monitoring, measurement, analysis and evaluation

Summary: Determine what to monitor/measure, methods, frequency, and who; evaluate ISMS performance and effectiveness.

KeyRequirements:

- Define what to monitor/measure and evaluate ISMS effectiveness.
- Run internal audits and management reviews at planned intervals.
- Track actions and decisions from audits and reviews.

TypicalEvidence:

- monitoring/measurement plan and results
- internal audit plan and reports
- management review minutes and actions

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-9.2

Type: ISO27001_Requirement

ClauseID: CL9.2

Subclause: 9.2

Title: Internal audit

Summary: Conduct internal audits at planned intervals; define criteria/scope; report results; retain evidence.

KeyRequirements:

- Define what to monitor/measure and evaluate ISMS effectiveness.
- Run internal audits and management reviews at planned intervals.
- Track actions and decisions from audits and reviews.

TypicalEvidence:

- monitoring/measurement plan and results
- internal audit plan and reports
- management review minutes and actions

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-9.3

Type: ISO27001_Requirement

ClauseID: CL9.3

Subclause: 9.3

Title: Management review

Summary: Top management reviews ISMS at planned intervals to ensure continuing suitability, adequacy, and effectiveness.

KeyRequirements:

- Define what to monitor/measure and evaluate ISMS effectiveness.
- Run internal audits and management reviews at planned intervals.
- Track actions and decisions from audits and reviews.

TypicalEvidence:

-

- monitoring/measurement plan and results
- internal audit plan and reports
- management review minutes and actions

[CHUNK_END]

Clause 10 — Improvement

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-10.1

Type: ISO27001_Requirement

ClauseID: CL10.1

Subclause: 10.1

Title: Continual improvement

Summary: Continually improve suitability, adequacy, and effectiveness of the ISMS.

KeyRequirements:

- Maintain a corrective action process for nonconformities.
- Drive continual improvement using performance results, audits, incidents, and changes.
- Update risks, controls, and documentation based on corrective actions.

TypicalEvidence:

- corrective action records
- continual improvement log / backlog

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-REQ-10.2

Type: ISO27001_Requirement

ClauseID: CL10.2

Subclause: 10.2

Title: Nonconformity and corrective action

Summary: React to nonconformity, correct it, deal with consequences; evaluate causes; implement corrective action; review effectiveness; update ISMS.

KeyRequirements:

- Maintain a corrective action process for nonconformities.
- Drive continual improvement using performance results, audits, incidents, and changes.
- Update risks, controls, and documentation based on corrective actions.

TypicalEvidence:

- corrective action records
- continual improvement log / backlog Part 2 — Annex A Controls Catalog (ISO/IEC 27001:2022)

Annex A in ISO/IEC 27001:2022 presents a reference set of 93 information security

controls, grouped into four themes: Organizational (37), People (8), Physical (14), and Technological (34). Organizations select and justify applicable controls through risk treatment and record decisions in a Statement of Applicability (SoA).

- Annex A quick index (IDs by theme) Theme Control IDs (range) Organizational 5.1–5.37

People 6.1–6.8 Physical 7.1–7.14 Technological 8.1–8.34

[CHUNK_END]

Part 2 — Annex A Controls (93 controls)

Controls are grouped by the four 2022 themes. Each control includes a ControlID in A.x.y format.

Organizational controls

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.1

Type: AnnexA_Control

ControlID: A.5.1

Theme: Organizational

ControlTitle: Information security policies

Summary: Implement and maintain this control in a way that reduces the relevant information

security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.2

Type: AnnexA_Control

ControlID: A.5.2

Theme: Organizational

ControlTitle: Security roles and responsibilities

Summary: Assign clear information security responsibilities and authorities so security tasks are owned and executed. Ensure reporting lines and decision rights are explicit.

ImplementationChecklist:

- Define roles (e.g., ISMS owner, risk owners, control owners) and responsibilities.
- Integrate responsibilities into job descriptions and onboarding.
- Review role assignments when org structure or services change.

EvidenceExamples:

- RACI / responsibility matrix.
- Job descriptions and organizational charts.
- Access to relevant governance meetings and decisions.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.3

Type: AnnexA_Control

ControlID: A.5.3

Theme: Organizational

ControlTitle: Segregation of duties

Summary: Reduce the risk of errors or fraud by separating incompatible duties and access. Ensure critical actions require independent review or dual control.

ImplementationChecklist:

- Identify high-risk processes (payments, changes, privileged admin actions).
- Design separation (different people, approvals, or technical enforcement).
- Monitor exceptions and approve compensating controls where separation is not possible.

EvidenceExamples:

- Process maps and approval workflows.
- Access control rules enforcing separation.
- Exception register and approvals.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.4

Type: AnnexA_Control

ControlID: A.5.4

Theme: Organizational

ControlTitle: Management responsibilities

Summary: Assign clear information security responsibilities and authorities so security tasks are owned and executed. Ensure reporting lines and decision rights are

explicit.

ImplementationChecklist:

- Define roles (e.g., ISMS owner, risk owners, control owners) and responsibilities.
- Integrate responsibilities into job descriptions and onboarding.
- Review role assignments when org structure or services change.

EvidenceExamples:

- RACI / responsibility matrix.
- Job descriptions and organizational charts.
- Access to relevant governance meetings and decisions.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.5

Type: AnnexA_Control

ControlID: A.5.5

Theme: Organizational

ControlTitle: Contact with authorities

Summary: Maintain up-to-date contact mechanisms with relevant regulators or authorities for security and legal matters. Ensure escalation paths exist for incidents.

ImplementationChecklist:

- Identify relevant authorities for jurisdictions and sectors you operate in.
- Define when and how to contact them (including incident notification).
- Test contact details and escalation paths periodically.

EvidenceExamples:

- Authority contact list and notification procedure.
- Incident response playbooks.
- Test results / tabletop exercise records.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.6

Type: AnnexA_Control

ControlID: A.5.6

Theme: Organizational

ControlTitle: Contact with special interest groups

Summary: Engage with relevant security and industry communities to stay informed about threats, good practices, and expectations. Use insights to improve controls.

ImplementationChecklist:

- Identify and join appropriate industry/security groups.
- Define how insights are captured and shared internally.
- Feed relevant intelligence into risk assessment and control improvements.

EvidenceExamples:

- Membership records or subscriptions.
- Shared intelligence reports or briefings.
- Risk register updates referencing intelligence.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.7

Type: AnnexA_Control

ControlID: A.5.7

Theme: Organizational

ControlTitle: Threat intelligence

Summary: Collect and analyze threat information relevant to your organization to inform prevention, detection, and response. Use intelligence to prioritize actions.

ImplementationChecklist:

- Define sources (ISACs, vendors, CERT advisories, telemetry).
- Establish a process to triage and act on intelligence (patching, detections, awareness).
- Review effectiveness of intelligence sources and actions.

EvidenceExamples:

- Threat intel process document.
- Records of advisories and actions taken.
- Detection rule updates and patch tickets.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.8

Type: AnnexA_Control

ControlID: A.5.8

Theme: Organizational

ControlTitle: Security in project management

Summary: Integrate security into project governance so new or changed systems are designed securely. Ensure security requirements and risk reviews occur during delivery.

ImplementationChecklist:

- Include security checkpoints in the project lifecycle (design, build, test, release).
- Perform risk assessment for significant changes.
- Define acceptance criteria and sign-offs for security-relevant deliverables.

EvidenceExamples:

- Project templates with security tasks.
- Security review or architecture review records.
- Release approvals and testing evidence.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.9

Type: AnnexA_Control

ControlID: A.5.9

Theme: Organizational

ControlTitle: Inventory of information and assets

Summary: Maintain an inventory of information and associated assets so you can protect, monitor, and manage them throughout their lifecycle.

ImplementationChecklist:

- Define what counts as an asset and what metadata to record (owner, location, classification).
- Keep the inventory current as assets are created, changed, or retired.
- Use the inventory to drive access control, retention, and risk management.

EvidenceExamples:

- Asset / information register.
- Ownership and classification fields populated.
- Periodic inventory review records.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.10

Type: AnnexA_Control

ControlID: A.5.10

Theme: Organizational

ControlTitle: Acceptable use of information and assets

Summary: Define how information and assets may be used to reduce misuse and accidental leakage. Ensure users understand permitted and prohibited actions.

ImplementationChecklist:

- Document acceptable use rules for devices, networks, accounts, and data.
- Communicate rules through onboarding and periodic refreshers.
- Enforce key rules through technical controls and monitoring where feasible.

EvidenceExamples:

- Acceptable use policy.
- Training/attestation records.
- Enforcement configurations (MDM, DLP, logging).

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.11

Type: AnnexA_Control

ControlID: A.5.11

Theme: Organizational

ControlTitle: Return of assets

Summary: Ensure organizational assets are returned when people leave or change roles to prevent loss of equipment, data, or access.

ImplementationChecklist:

- Define offboarding and role-change checklists for asset return.
- Track assigned assets and verify return or secure disposal.
- Disable or transfer access and accounts as part of the process.

EvidenceExamples:

- Offboarding checklist records.
- Asset assignment logs.
- Account deprovisioning tickets/logs.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.12

Type: AnnexA_Control

ControlID: A.5.12

Theme: Organizational

ControlTitle: Information classification

Summary: Classify information based on sensitivity and business impact so protections are proportional to risk.

ImplementationChecklist:

- Define classification levels and handling requirements.
- Assign classifications to key datasets and information types.
- Review classifications when data or business use changes.

EvidenceExamples:

- Classification scheme document.
- Data inventory with classification labels.
- Periodic classification review reports.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.13

Type: AnnexA_Control

ControlID: A.5.13

Theme: Organizational

ControlTitle: Information labelling

Summary: Apply labels or metadata to information to support consistent handling and protection according to classification.

ImplementationChecklist:

- Define labeling rules and formats for each classification.

- Automate labeling where possible (email, documents, storage).
- Train users and audit labeling accuracy for critical information.

EvidenceExamples:

- Labeling standard and examples.
- Tool configurations (MIP/labels).
- Sample audit results for labeling.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.14

Type: AnnexA_Control

ControlID: A.5.14

Theme: Organizational

ControlTitle: Information transfer

Summary: Protect information when it is transferred internally or externally so confidentiality and integrity are maintained.

ImplementationChecklist:

- Define approved transfer methods (encrypted email, secure portals, APIs).
- Set requirements for recipients, authentication, and encryption.
- Log or track transfers for sensitive information and investigate anomalies.

EvidenceExamples:

- Information transfer procedure.
- Encryption and secure channel configurations.
- Transfer logs and approvals for sensitive data.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.15

Type: AnnexA_Control

ControlID: A.5.15

Theme: Organizational

ControlTitle: Access control governance

Summary: Establish access control rules that ensure information and systems are accessible only to authorized entities and for approved purposes.

ImplementationChecklist:

- Define access control principles (least privilege, need-to-know).
- Implement role-based or attribute-based access where practical.
- Review access periodically and on changes to roles or systems.

EvidenceExamples:

- Access control policy/standard.
- Access request/approval records.
- Access review reports.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.16

Type: AnnexA_Control

ControlID: A.5.16

Theme: Organizational

ControlTitle: Identity management

Summary: Manage digital identities throughout their lifecycle so users and systems can be reliably identified.

ImplementationChecklist:

- Implement joiner-mover-leaver processes for accounts.
- Use unique identifiers and avoid shared accounts where possible.
- Review identity records and reconcile with HR or source-of-truth systems.

EvidenceExamples:

- IAM process documentation.
- Provisioning/deprovisioning logs.
- Periodic identity reconciliation reports.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.17

Type: AnnexA_Control

ControlID: A.5.17

Theme: Organizational

ControlTitle: Authentication information

Summary: Protect authentication secrets (passwords, keys, tokens) so they cannot be stolen or misused.

ImplementationChecklist:

- Define standards for password/secret creation and storage.
- Use secure vaults and avoid hardcoding secrets.
- Rotate and revoke secrets when compromise is suspected or roles change.

EvidenceExamples:

- Secret management policy.
- Vault configuration and access logs.
- Secret rotation records.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.18

Type: AnnexA_Control

ControlID: A.5.18

Theme: Organizational

ControlTitle: Access rights management

Summary: Control granting, changing, and revoking access rights so privileges match current responsibilities and risk.

ImplementationChecklist:

- Define an approval workflow for access changes.
- Automate provisioning and deprovisioning where possible.
- Conduct periodic access reviews, focusing on high-risk systems.

EvidenceExamples:

- Access management procedure.
- Tickets/approvals for access changes.
- Access review outcomes and remediations.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.19

Type: AnnexA_Control

ControlID: A.5.19

Theme: Organizational

ControlTitle: Security in supplier relationships

Summary: Manage information security risks from suppliers by setting expectations and ensuring supplier activities do not compromise your information.

ImplementationChecklist:

- Assess supplier security risk before onboarding and periodically.
- Define security requirements (confidentiality, incident notification, access).
- Ensure supplier access is controlled and monitored.

EvidenceExamples:

- Supplier risk assessments.
- Supplier security requirements in contracts.
- Supplier access logs and reviews.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.20

Type: AnnexA_Control

ControlID: A.5.20

Theme: Organizational

ControlTitle: Security within supplier agreements

Summary: Manage information security risks from suppliers by setting expectations and ensuring supplier activities do not compromise your information.

ImplementationChecklist:

- Assess supplier security risk before onboarding and periodically.
- Define security requirements (confidentiality, incident notification, access).
- Ensure supplier access is controlled and monitored.

EvidenceExamples:

- Supplier risk assessments.
- Supplier security requirements in contracts.
- Supplier access logs and reviews.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.21

Type: AnnexA_Control

ControlID: A.5.21

Theme: Organizational

ControlTitle: ICT supply chain security

Summary: Manage security risks across the ICT supply chain, including vendors, sub-processors, and components, to reduce compromise through upstream dependencies.

ImplementationChecklist:

- Identify critical dependencies and third parties in the chain.
- Set requirements for secure development, integrity, and provenance where applicable.
- Monitor supplier performance and handle changes to supply chain risk.

EvidenceExamples:

- Supply chain mapping.
- Vendor assurance evidence (SOC reports, attestations).
- Monitoring and review records.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.22

Type: AnnexA_Control

ControlID: A.5.22

Theme: Organizational

ControlTitle: Monitoring and change of supplier services

Summary: Monitor supplier services for security-relevant changes and performance so emerging risks are identified and managed.

ImplementationChecklist:

- Define security KPIs/SLAs and monitoring signals for supplier services.
- Review changes to supplier scope, sub-processors, or architecture.
- Escalate and remediate issues through defined governance.

EvidenceExamples:

- Supplier performance review minutes.
- Change notifications and risk reviews.

- Issue logs and remediation actions.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.23

Type: AnnexA_Control

ControlID: A.5.23

Theme: Organizational

ControlTitle: Security for use of cloud services

Summary: Apply security requirements to the selection and use of cloud services, including configuration, shared responsibility, and monitoring.

ImplementationChecklist:

- Define cloud security baseline and shared responsibility ownership.
- Harden configurations (identity, network, logging) and manage misconfigurations.
- Monitor cloud usage and provider changes; reassess risks periodically.

EvidenceExamples:

- Cloud security standards and baselines.
- Configuration audit results (CSPM).
- Cloud logging/monitoring evidence.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.24

Type: AnnexA_Control

ControlID: A.5.24

Theme: Organizational

ControlTitle: Incident management planning and preparation

Summary: Prepare for information security incidents with documented plans, roles, and resources so response is timely and consistent.

ImplementationChecklist:

- Define incident categories, severity levels, and escalation criteria.
- Create response playbooks and communication templates.
- Run exercises and update plans based on lessons learned.

EvidenceExamples:

- Incident response plan and playbooks.
- Exercise reports/tabletop results.
- On-call rosters and contact lists.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.25

Type: AnnexA_Control

ControlID: A.5.25

Theme: Organizational

ControlTitle: Assess and decide on security events

Summary: Implement and maintain this control in a way that reduces the relevant information security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.26

Type: AnnexA_Control

ControlID: A.5.26

Theme: Organizational

ControlTitle: Respond to security incidents

Summary: Implement and maintain this control in a way that reduces the relevant information security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.27

Type: AnnexA_Control

ControlID: A.5.27

Theme: Organizational

ControlTitle: Learn from security incidents

Summary: Implement and maintain this control in a way that reduces the relevant information security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.28

Type: AnnexA_Control

ControlID: A.5.28

Theme: Organizational

ControlTitle: Collect and preserve evidence

Summary: Collect and protect evidence so it remains reliable for investigations, audits, and legal or disciplinary processes.

ImplementationChecklist:

- Define evidence handling and chain-of-custody procedures.
- Ensure logs and artifacts are time-synchronized and protected from tampering.
- Limit access to evidence and document transfers.

EvidenceExamples:

- Evidence handling procedure.
- Chain-of-custody records.
- Protected log storage configuration.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.29

Type: AnnexA_Control

ControlID: A.5.29

Theme: Organizational

ControlTitle: Information security during disruption

Summary: Maintain appropriate information security when normal operations are disrupted (e.g., outages, crises) so risks do not increase uncontrollably.

ImplementationChecklist:

- Define security requirements for emergency modes of operation.
- Ensure alternative processes maintain access control and logging where possible.
- Review and test disruption procedures as part of continuity planning.

EvidenceExamples:

- Disruption security procedures.
- BCP/DR plans incorporating security.
- Test/exercise records.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.30

Type: AnnexA_Control

ControlID: A.5.30

Theme: Organizational

ControlTitle: ICT readiness for business continuity

Summary: Ensure ICT capabilities support business continuity objectives, including recovery time and recovery point needs.

ImplementationChecklist:

- Define recovery requirements for critical services (RTO/RPO).
- Implement backups, redundancy, and recovery procedures.
- Test recovery regularly and track improvements.

EvidenceExamples:

- BCP/DR requirements and plans.
- Backup and recovery test results.
- System redundancy design evidence.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.31

Type: AnnexA_Control

ControlID: A.5.31

Theme: Organizational

ControlTitle: Legal, regulatory, and contractual requirements

Summary: Identify and comply with legal, regulatory, and contractual requirements related to information security and privacy.

ImplementationChecklist:

- Maintain a register of applicable obligations and owners.
- Map obligations to policies, controls, and procedures.
- Review obligations when services, locations, or laws change.

EvidenceExamples:

- Compliance obligations register.
- Policy/control mappings.
- Compliance review and audit results.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.32

Type: AnnexA_Control

ControlID: A.5.32

Theme: Organizational

ControlTitle: Intellectual property protection

Summary: Protect intellectual property rights by controlling use, licensing, and disclosure of protected materials.

ImplementationChecklist:

- Identify IP assets and relevant licenses/rights.
- Define rules for software licensing and content use.
- Monitor compliance and respond to suspected infringement or leakage.

EvidenceExamples:

- IP register and license inventory.
- Policies on acceptable software/content use.
- Compliance check records.
-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.33

Type: AnnexA_Control

ControlID: A.5.33

Theme: Organizational

ControlTitle: Protection of records

Summary: Protect organizational records against loss, tampering, and unauthorized access while meeting retention and disposal requirements.

ImplementationChecklist:

- Define record categories and retention periods.
- Protect records with access control, integrity measures, and backups.
- Dispose of records securely at end of retention.

EvidenceExamples:

- Records management policy.
- Retention schedule and disposal logs.
- Access control and backup evidence for record repositories.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.34

Type: AnnexA_Control

ControlID: A.5.34

Theme: Organizational

ControlTitle: Privacy and protection of PII

Summary: Protect personal information and privacy by implementing controls aligned to applicable privacy requirements and risk.

ImplementationChecklist:

- Identify personal data processing activities and risks.
- Implement data minimization, access control, and secure processing.
- Define incident response steps for personal data breaches where required.

EvidenceExamples:

- Data processing inventory (RoPA) or equivalent.
- Privacy policies and notices.
- Access controls and breach response records.
-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.35

Type: AnnexA_Control

ControlID: A.5.35

Theme: Organizational

ControlTitle: Independent review of information security

Summary: Conduct independent reviews of the information security program to verify suitability and effectiveness and to identify gaps.

ImplementationChecklist:

- Define review scope and independence criteria.
- Perform reviews at planned intervals or after major changes.
- Track findings to closure with owners and due dates.

EvidenceExamples:

- Review/audit reports.
- Management action plans.
- Evidence of closure for findings.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.36

Type: AnnexA_Control

ControlID: A.5.36

Theme: Organizational

ControlTitle: Compliance with policies, rules, and standards

Summary: Ensure compliance with information security policies and standards through monitoring, review, and corrective action.

ImplementationChecklist:

- Define how compliance is checked (audits, monitoring, attestations).
- Investigate and address noncompliance.
- Report compliance status to management.

EvidenceExamples:

- Compliance monitoring results.
- Nonconformity and corrective action records.
- Management reporting artifacts.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.5.37

Type: AnnexA_Control

ControlID: A.5.37

Theme: Organizational

ControlTitle: Documented operating procedures

Summary: Document operating procedures for security-relevant activities so they are performed consistently and can be audited.

ImplementationChecklist:

- Identify recurring security-relevant tasks that need procedures.
- Ensure procedures are accessible to authorized staff and kept current.
- Train operators and verify procedure adherence.

EvidenceExamples:

- Standard operating procedures (SOPs).
- Change history and approvals.
- Operational checklists and run logs.

-

- People Controls

[CHUNK_END]

People controls

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.6.1

Type: AnnexA_Control

ControlID: A.6.1

Theme: People

ControlTitle: Screening

Summary: Perform background or pre-employment checks consistent with law and role risk to reduce insider and fraud risk.

ImplementationChecklist:

- Define screening levels by role risk and jurisdiction.
- Obtain consent and perform checks via approved providers.
- Re-screen or verify when required by policy or law.

EvidenceExamples:

- Screening policy.
- Completed screening records.
- Exception approvals.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.6.2

Type: AnnexA_Control

ControlID: A.6.2

Theme: People

ControlTitle: Terms and conditions of employment

Summary: Ensure security responsibilities are included in employment terms so expectations are legally and operationally clear.

ImplementationChecklist:

- Include confidentiality and security responsibilities in contracts.
- Communicate policies during onboarding.
- Update terms when roles or obligations change.

EvidenceExamples:

- Employment contract templates.
- Signed acknowledgements.
- HR policy records.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.6.3

Type: AnnexA_Control

ControlID: A.6.3

Theme: People

ControlTitle: Security awareness, training, and education

Summary: Implement and maintain this control in a way that reduces the relevant information security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.6.4

Type: AnnexA_Control

ControlID: A.6.4

Theme: People

ControlTitle: Disciplinary process

Summary: Define a disciplinary process for intentional or negligent security policy violations to reinforce accountability.

ImplementationChecklist:

- Define what constitutes a violation and severity levels.
- Coordinate HR, legal, and security for investigations.
- Document actions taken and ensure consistency.

EvidenceExamples:

- Disciplinary policy.
- Case records with approvals.
- Training and communication records.
-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.6.5

Type: AnnexA_Control

ControlID: A.6.5

Theme: People

ControlTitle: Responsibilities after termination or role change

Summary: Assign clear information security responsibilities and authorities so security tasks are owned and executed. Ensure reporting lines and decision rights are explicit.

ImplementationChecklist:

- Define roles (e.g., ISMS owner, risk owners, control owners) and responsibilities.
- Integrate responsibilities into job descriptions and onboarding.
- Review role assignments when org structure or services change.

EvidenceExamples:

- RACI / responsibility matrix.
- Job descriptions and organizational charts.
- Access to relevant governance meetings and decisions.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.6.6

Type: AnnexA_Control

ControlID: A.6.6

Theme: People

ControlTitle: Confidentiality / non-disclosure agreements

Summary: Implement and maintain this control in a way that reduces the relevant information security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.
-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.6.7

Type: AnnexA_Control

ControlID: A.6.7

Theme: People

ControlTitle: Remote working

Summary: Secure remote work by defining requirements for devices, networks, access, and handling of information outside controlled premises.

ImplementationChecklist:

- Define remote work rules for devices, VPN/Zero Trust, and data handling.
- Apply endpoint security, encryption, and strong authentication.
- Monitor remote access and address higher-risk activities (admin, sensitive data).

EvidenceExamples:

- Remote working policy.
- MDM/EDR configuration evidence.
- Remote access logs and reviews.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.6.8

Type: AnnexA_Control

ControlID: A.6.8

Theme: People

ControlTitle: Security event reporting

Summary: Enable timely reporting of security events so potential incidents are identified and handled early.

ImplementationChecklist:

- Define what to report and how (channels, hotline, ticketing).
- Train users and contractors on reporting expectations.
- Track and triage reports and provide feedback loops.

EvidenceExamples:

- Reporting procedure and channels.
- Training materials.
- Event tickets and response records.

-

- Physical Controls

[CHUNK_END]

Physical controls

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.7.1

Type: AnnexA_Control

ControlID: A.7.1

Theme: Physical

ControlTitle: Physical security perimeters

Summary: Use physical boundaries and controls to restrict access to areas where sensitive information is processed or stored.

ImplementationChecklist:

- Define secure areas and required perimeter controls (walls, doors, fencing).
- Control access points and maintain visitor management.
- Inspect perimeters and repair weaknesses promptly.

EvidenceExamples:

- Site security plans.
- Access control system logs.
- Visitor logs and inspection records.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.7.2

Type: AnnexA_Control

ControlID: A.7.2

Theme: Physical

ControlTitle: Physical entry controls

Summary: Control physical entry to facilities and secure areas so only authorized people gain access.

ImplementationChecklist:

- Implement badges/keys/biometrics based on risk.
- Issue, revoke, and review physical access rights.
- Ensure escorting and logging for visitors where needed.

EvidenceExamples:

- Physical access policy.
- Badge issuance and revocation records.
- Access logs and visitor records.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.7.3

Type: AnnexA_Control

ControlID: A.7.3

Theme: Physical

ControlTitle: Secure offices, rooms, and facilities

Summary: Implement and maintain this control in a way that reduces the relevant information security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.7.4

Type: AnnexA_Control

ControlID: A.7.4

Theme: Physical

ControlTitle: Physical security monitoring

Summary: Monitor physical security with appropriate detection and surveillance to deter and detect unauthorized activity.

ImplementationChecklist:

- Deploy monitoring (CCTV, alarms) based on risk and privacy requirements.
- Define retention and access controls for footage and logs.
- Test alarms and review monitoring effectiveness periodically.

EvidenceExamples:

- CCTV/alarm configurations.
- Monitoring review records.
- Incident records referencing physical monitoring.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.7.5

Type: AnnexA_Control

ControlID: A.7.5

Theme: Physical

ControlTitle: Protect against physical and environmental threats

Summary: Implement and maintain this control in a way that reduces the relevant information security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.7.6

Type: AnnexA_Control

ControlID: A.7.6

Theme: Physical

ControlTitle: Work in secure areas

Summary: Implement and maintain this control in a way that reduces the relevant information security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.7.7

Type: AnnexA_Control

ControlID: A.7.7

Theme: Physical

ControlTitle: Clear desk and clear screen

Summary: Reduce exposure of sensitive information by keeping desks and screens clear when unattended or not in use.

ImplementationChecklist:

- Define clear desk/screen rules for sensitive information.
- Implement screen locks and secure storage for documents/media.
- Audit adherence in relevant areas.

EvidenceExamples:

- Clear desk/screen policy.
- System screen-lock settings.
- Inspection/audit records.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.7.8

Type: AnnexA_Control

ControlID: A.7.8

Theme: Physical

ControlTitle: Equipment siting and protection

Summary: Implement and maintain this control in a way that reduces the relevant information

security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.7.9

Type: AnnexA_Control

ControlID: A.7.9

Theme: Physical

ControlTitle: Assets off-premises

Summary: Implement and maintain this control in a way that reduces the relevant information security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.7.10

Type: AnnexA_Control

ControlID: A.7.10

Theme: Physical

ControlTitle: Storage media

Summary: Secure storage media throughout its lifecycle to prevent loss, theft, or unauthorized disclosure.

ImplementationChecklist:

- Define handling, encryption, and transport rules for removable media.
- Maintain media inventory for sensitive use cases.
- Securely erase or destroy media at end of life.

EvidenceExamples:

- Media handling policy.
- Encryption settings for removable media.
- Media destruction certificates/logs.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.7.11

Type: AnnexA_Control

ControlID: A.7.11

Theme: Physical

ControlTitle: Supporting utilities

Summary: Implement and maintain this control in a way that reduces the relevant information security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.7.12

Type: AnnexA_Control

ControlID: A.7.12

Theme: Physical

ControlTitle: Cabling security

Summary: Implement and maintain this control in a way that reduces the relevant information security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.7.13

Type: AnnexA_Control

ControlID: A.7.13

Theme: Physical

ControlTitle: Equipment maintenance

Summary: Implement and maintain this control in a way that reduces the relevant information security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.7.14

Type: AnnexA_Control

ControlID: A.7.14

Theme: Physical

ControlTitle: Secure disposal or re-use of equipment

Summary: Dispose of or reuse equipment securely so data cannot be recovered by unauthorized parties.

ImplementationChecklist:

- Define sanitization methods (wipe, degauss, shred) by media type.

- Verify sanitization before reuse or disposal.
- Use approved disposal vendors and document chain of custody.

EvidenceExamples:

- Disposal and sanitization procedure.
- Wipe logs / certificates of destruction.
- Asset disposal records.

-

- Technological Controls

[CHUNK_END]

Technological controls

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.1

Type: AnnexA_Control

ControlID: A.8.1

Theme: Technological

ControlTitle: User endpoint devices

Summary: Secure user endpoints (laptops, mobiles) with hardening, patching, encryption, and monitoring to reduce compromise risk.

ImplementationChecklist:

- Define endpoint baseline (OS hardening, encryption, EDR).
- Manage patches and software centrally where possible.
- Monitor endpoint health and respond to alerts.

EvidenceExamples:

- Endpoint baseline standards.
- MDM/EDR dashboards and reports.
- Patch compliance reports.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.2

Type: AnnexA_Control

ControlID: A.8.2

Theme: Technological

ControlTitle: Privileged access rights

Summary: Control granting, changing, and revoking access rights so privileges match current responsibilities and risk.

ImplementationChecklist:

- Define an approval workflow for access changes.
- Automate provisioning and deprovisioning where possible.
- Conduct periodic access reviews, focusing on high-risk systems.

EvidenceExamples:

- Access management procedure.
- Tickets/approvals for access changes.
- Access review outcomes and remediations.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.3

Type: AnnexA_Control

ControlID: A.8.3

Theme: Technological

ControlTitle: Restrict information access

Summary: Implement and maintain this control in a way that reduces the relevant information security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.4

Type: AnnexA_Control

ControlID: A.8.4

Theme: Technological

ControlTitle: Access to source code

Summary: Protect source code repositories and related assets from unauthorized access and alteration.

ImplementationChecklist:

- Restrict repository access and enforce least privilege.
- Use code review, branch protection, and signed commits where feasible.
- Monitor repository activity and protect secrets in code.

EvidenceExamples:

- Repo access control settings.
- Branch protection / review rules.
- Audit logs from version control systems.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.5

Type: AnnexA_Control

ControlID: A.8.5

Theme: Technological

ControlTitle: Secure authentication

Summary: Implement and maintain this control in a way that reduces the relevant information security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.6

Type: AnnexA_Control

ControlID: A.8.6

Theme: Technological

ControlTitle: Capacity management

Summary: Manage capacity so systems remain available and secure under expected and peak loads.

ImplementationChecklist:

- Monitor resource usage and trends.
- Define scaling thresholds and plans.

- Test resilience for critical services.

EvidenceExamples:

- Capacity monitoring dashboards.
- Scaling/runbook documentation.
- Post-incident capacity reviews.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.7

Type: AnnexA_Control

ControlID: A.8.7

Theme: Technological

ControlTitle: Protection against malware

Summary: Prevent, detect, and respond to malware across systems to reduce infection and lateral movement.

ImplementationChecklist:

- Deploy anti-malware/EDR and keep signatures/rules updated.
- Restrict execution of untrusted code (allowlisting where appropriate).
- Define response actions for detections.

EvidenceExamples:

- EDR/anti-malware deployment evidence.
- Detection and response tickets.
- Allowlisting policies/config.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.8

Type: AnnexA_Control

ControlID: A.8.8

Theme: Technological

ControlTitle: Technical vulnerability management

Summary: Identify, assess, and remediate technical vulnerabilities in a timely manner based on risk.

ImplementationChecklist:

- Maintain an asset and software inventory for scanning.
- Scan and track vulnerabilities with risk-based SLAs.
- Validate remediation and manage exceptions.

EvidenceExamples:

- Vulnerability scan reports.
- Remediation tickets and SLAs.
- Exception/risk acceptance records.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.9

Type: AnnexA_Control

ControlID: A.8.9

Theme: Technological

ControlTitle: Configuration management

Summary: Control system configurations to reduce exposure, maintain consistency, and detect unauthorized changes.

ImplementationChecklist:

- Define secure baselines for key platforms.
- Manage changes through version control and approval.
- Detect drift and remediate deviations.

EvidenceExamples:

- Baseline configuration standards.
- IaC repositories or config management records.
- Drift/compliance reports.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.10

Type: AnnexA_Control

ControlID: A.8.10

Theme: Technological

ControlTitle: Information deletion

Summary: Implement and maintain this control in a way that reduces the relevant information security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.11

Type: AnnexA_Control

ControlID: A.8.11

Theme: Technological

ControlTitle: Data masking

Summary: Implement and maintain this control in a way that reduces the relevant information security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.12

Type: AnnexA_Control

ControlID: A.8.12

Theme: Technological

ControlTitle: Data leakage prevention

Summary: Reduce unauthorized disclosure of sensitive data using preventive and detective measures such as content controls and monitoring.

ImplementationChecklist:

- Define what data needs leakage controls and where it resides.
- Implement DLP rules for endpoints, email, and cloud storage as applicable.
- Tune rules and investigate alerts.

EvidenceExamples:

- DLP policy and data categories.

- DLP rule configurations.
- DLP alert handling records.
-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.13

Type: AnnexA_Control

ControlID: A.8.13

Theme: Technological

ControlTitle: Information backup

Summary: Back up information and systems to support recovery from loss, corruption, or ransomware.

ImplementationChecklist:

- Define backup scope, frequency, and retention (including offline/immutable where needed).
- Protect backups with access control and encryption.
- Test restores and track success rates.

EvidenceExamples:

- Backup policy and schedules.
- Backup job logs and alerts.
- Restore test reports.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.14

Type: AnnexA_Control

ControlID: A.8.14

Theme: Technological

ControlTitle: Redundancy of processing facilities

Summary: Implement redundancy for critical processing facilities to reduce downtime and single points of failure.

ImplementationChecklist:

- Identify components requiring redundancy (compute, network, storage).
- Design for failover and test it.
- Monitor redundancy health and capacity.

EvidenceExamples:

- Architecture diagrams.
- Failover test records.
- Monitoring reports.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.15

Type: AnnexA_Control

ControlID: A.8.15

Theme: Technological

ControlTitle: Logging

Summary: Generate and protect logs so security-relevant activity can be detected, investigated, and audited.

ImplementationChecklist:

- Define log sources and required events.
- Centralize logs and protect integrity and access.
- Define retention and monitoring use cases.

EvidenceExamples:

- Logging standard.
- SIEM configurations.

- Log retention and access control evidence.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.16

Type: AnnexA_Control

ControlID: A.8.16

Theme: Technological

ControlTitle: Monitoring activities

Summary: Monitor systems and networks for suspicious activity to detect incidents quickly and reduce dwell time.

ImplementationChecklist:

- Define monitoring use cases and alert thresholds.
- Integrate telemetry into SOC workflows.
- Review alert quality and tune detections.

EvidenceExamples:

- Detection rules and playbooks.
- Alert handling tickets.
- Monitoring performance metrics.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.17

Type: AnnexA_Control

ControlID: A.8.17

Theme: Technological

ControlTitle: Clock synchronization

Summary: Synchronize system clocks so logs and security events can be correlated accurately.

ImplementationChecklist:

- Use authoritative time sources (NTP) for systems and network devices.
- Monitor time sync status and drift.
- Define requirements for high-integrity environments.

EvidenceExamples:

- NTP configuration evidence.
- Monitoring reports on time sync.
- Audit evidence correlating timestamps.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.18

Type: AnnexA_Control

ControlID: A.8.18

Theme: Technological

ControlTitle: Use of privileged utility programs

Summary: Control use of powerful administrative utilities to prevent misuse and maintain accountability.

ImplementationChecklist:

- Restrict utilities to authorized administrators.
- Log and monitor their use.
- Harden endpoints where utilities are executed (jump hosts).

EvidenceExamples:

- Access controls for admin tools.
- Logs of privileged utility usage.
- Jump host configurations.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.19

Type: AnnexA_Control

ControlID: A.8.19

Theme: Technological

ControlTitle: Software installation on operational systems

Summary: Control software installation on production systems to reduce malware risk and unauthorized changes.

ImplementationChecklist:

- Define approved software and installation process.
- Restrict installation privileges.
- Monitor and remediate unapproved software.

EvidenceExamples:

- Software allowlist/standard.
- Endpoint privilege configurations.
- Software inventory reports.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.20

Type: AnnexA_Control

ControlID: A.8.20

Theme: Technological

ControlTitle: Network security

Summary: Secure networks with appropriate segmentation, filtering, and controls to protect data flows and reduce attack paths.

ImplementationChecklist:

- Define network zones and trust boundaries.
- Use firewalls and secure configurations for routing/switching.
- Monitor network traffic for anomalies.

EvidenceExamples:

- Network architecture diagrams.
- Firewall rules and change logs.
- Network monitoring alerts and reports.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.21

Type: AnnexA_Control

ControlID: A.8.21

Theme: Technological

ControlTitle: Security of network services

Summary: Ensure network services (e.g., DNS, DHCP, VPN) are secured, configured, and monitored because they are foundational dependencies.

ImplementationChecklist:

- Harden and restrict access to network service management.
- Apply secure configurations and patching.
- Monitor service availability and suspicious use.

EvidenceExamples:

- Configuration baselines for network services.
- Admin access logs.
- Service monitoring evidence.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.22

Type: AnnexA_Control

ControlID: A.8.22

Theme: Technological

ControlTitle: Segregation of networks

Summary: Reduce the risk of errors or fraud by separating incompatible duties and access.

Ensure critical actions require independent review or dual control.

ImplementationChecklist:

- Identify high-risk processes (payments, changes, privileged admin actions).
- Design separation (different people, approvals, or technical enforcement).
- Monitor exceptions and approve compensating controls where separation is not possible.

EvidenceExamples:

- Process maps and approval workflows.
- Access control rules enforcing separation.
- Exception register and approvals.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.23

Type: AnnexA_Control

ControlID: A.8.23

Theme: Technological

ControlTitle: Web filtering

Summary: Reduce exposure to malicious and inappropriate content by filtering web access based on risk.

ImplementationChecklist:

- Define categories or destinations to block/allow.
- Apply filtering to relevant users/devices/networks.
- Review exceptions and tune based on incidents.

EvidenceExamples:

- Web proxy/DNS filter configuration.
- Blocked/allowed list management records.
- Exception approvals.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.24

Type: AnnexA_Control

ControlID: A.8.24

Theme: Technological

ControlTitle: Use of cryptography

Summary: Use cryptography appropriately to protect confidentiality and integrity of information at rest and in transit.

ImplementationChecklist:

- Define where encryption is required and approved algorithms/key lengths.
- Manage keys securely (generation, storage, rotation).
- Validate correct use via reviews and testing.

EvidenceExamples:

- Cryptographic policy/standard.
- Key management system evidence.
- Encryption configuration samples.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.25

Type: AnnexA_Control

ControlID: A.8.25

Theme: Technological

ControlTitle: Secure development life cycle

Summary: Build security into the software development lifecycle so vulnerabilities are prevented and detected early.

ImplementationChecklist:

- Define SDLC security activities (threat modeling, code review, testing).
- Integrate security tooling (SAST, SCA, secrets scanning).
- Track and remediate findings before release.

EvidenceExamples:

- SDLC policy and checklists.
- Tool outputs and remediation tickets.
- Release gates and approvals.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.26

Type: AnnexA_Control

ControlID: A.8.26

Theme: Technological

ControlTitle: Application security requirements

Summary: Define security requirements for applications so design and implementation meet confidentiality, integrity, availability, and privacy needs.

ImplementationChecklist:

- Capture security requirements during planning/design.
- Translate requirements into acceptance criteria and test cases.
- Review requirements when threat model or usage changes.

EvidenceExamples:

- Requirements documents/user stories.
- Security test cases.
- Architecture review records.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.27

Type: AnnexA_Control

ControlID: A.8.27

Theme: Technological

ControlTitle: Secure system architecture and engineering principles

Summary: Apply secure architecture and engineering principles so systems are resilient against known threat patterns.

ImplementationChecklist:

- Use standardized secure design patterns and reference architectures.
- Review designs for trust boundaries and failure modes.
- Validate architecture via testing and review.

EvidenceExamples:

- Reference architectures and standards.
- Design review minutes.
- Security testing results.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.28

Type: AnnexA_Control

ControlID: A.8.28

Theme: Technological

ControlTitle: Secure coding

Summary: Follow secure coding practices to prevent common vulnerabilities such as injection, XSS, and insecure deserialization.

ImplementationChecklist:

- Adopt secure coding standards by language/framework.
- Use peer review and automated scanning for defects.
- Train developers and track recurring vulnerability themes.

EvidenceExamples:

- Secure coding guidelines.
- Code review records.
- SAST results and remediation evidence.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.29

Type: AnnexA_Control

ControlID: A.8.29

Theme: Technological

ControlTitle: Security testing in development and acceptance

Summary: Test security in development and acceptance to identify vulnerabilities before deployment.

ImplementationChecklist:

- Define required testing (SAST/DAST, pen tests, fuzzing) by risk.
- Run tests in CI/CD and before major releases.
- Track findings to closure with owners and timelines.

EvidenceExamples:

- Test plans and reports.
- CI/CD pipeline logs.
- Finding remediation tickets.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.30

Type: AnnexA_Control

ControlID: A.8.30

Theme: Technological

ControlTitle: Outsourced development

Summary: Manage security risks when development is outsourced by setting expectations, controlling access, and validating deliverables.

ImplementationChecklist:

- Define security requirements for outsourced teams.
- Control access to code and environments.
- Review deliverables and evidence of security testing.

EvidenceExamples:

- Outsourcing contracts with security clauses.
- Access logs for contractors.
- Delivered security test evidence.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.31

Type: AnnexA_Control

ControlID: A.8.31

Theme: Technological

ControlTitle: Separate dev, test, and production environments

Summary: Implement and maintain this control in a way that reduces the relevant information security risk, and review it periodically.

ImplementationChecklist:

- Document how the control is implemented and who owns it.
- Operate the control consistently and monitor effectiveness.
- Review and improve the control based on changes and incidents.

EvidenceExamples:

- Documented procedure or standard.
- Operational records/logs.
- Periodic review results.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.32

Type: AnnexA_Control

ControlID: A.8.32

Theme: Technological

ControlTitle: Change management

Summary: Control changes to systems so they are assessed, approved, tested, and traceable, reducing security and availability risk.

ImplementationChecklist:

- Define change categories and approval workflows.
- Assess security impact for significant changes.
- Log changes and validate outcomes post-deployment.

EvidenceExamples:

- Change management procedure.
- Change tickets with approvals.
- Deployment logs and rollback plans.

-

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.33

Type: AnnexA_Control

ControlID: A.8.33

Theme: Technological

ControlTitle: Test information protection

Summary: Protect test information so sensitive data is not exposed and test artifacts do not create new risks.

ImplementationChecklist:

- Define rules for using and protecting test data.
- Mask or anonymize sensitive data in test environments.
- Control access to test datasets and outputs.

EvidenceExamples:

- Test data policy.
- Data masking evidence.
- Access control logs for test data.

[CHUNK_END]

[CHUNK_START]

ChunkID: ISO27001-2022-ANNEXA-A.8.34

Type: AnnexA_Control

ControlID: A.8.34

Theme: Technological

ControlTitle: Protect systems during audit testing

Summary: Protect information systems during audit testing so audit activities do not introduce vulnerabilities or disruptions.

Implementation Checklist:

- Plan audit testing activities and obtain approvals.
- Limit scope and permissions for testing tools.
- Monitor and remediate issues found during audit testing.

Evidence Examples:

- Audit test plans and approvals.
- Logs of audit-related activities.
- Remediation records for audit findings.
- References used for cross-checking structure (public sources)
- ISO (standard landing page): ISO/IEC 27001:2022 — Information security management systems (iso.org/standard/27001)
- Secureframe: Clauses 4–10 overview and Annex A control set summary (secureframe.com/hub/iso-27001/clauses; secureframe.com/hub/iso-27001/controls)
- Advisera: Annex A control list by theme (advisera.com/iso27001/annex-a-controls/)
- PECB: Control group counts and examples of new controls in 2022 (pecb.com/en/article/iso-iec-27001-what-are-the-main-changes-in-2022)
- Pivot Point Security: ISO/IEC 27002:2022 shift to 93 controls / 4 themes (pivotpointsecurity.com/the-new-iso-270022022-whats-new-with-the-controls/) If you need the verbatim ISO/IEC 27001 requirements text for legal/audit purposes, obtain the official publication from ISO or your national standards body.
-

[CHUNK_END]